

Usability and Non-Functional Requirements

Standalone extract of the Phase 1 report

CSE 347/652 | DES 306/525 Usable Security and Privacy
IIIT-Delhi · Monsoon 2026 · Instructor: Dr. Arun Balaji Buduru

Phase 1: User Studies to evolve Requirements, Design and Workflows
Submission: 4 October 2026

Team: [INSERT TEAM MEMBER NAMES AND ROLL NUMBERS]

Primary research status: instruments complete; fieldwork data not yet collected. All placeholders are marked [DATA REQUIRED]. No primary data has been fabricated.

22. Usability Requirements

Grounded in Nielsen [15], Yee [13], Cranor [16], Adams & Sasse [10], Herley [11], WCAG 2.2 [28].

ID	Requirement	Rationale / user need	Evidence	Pri	Prototype feature	Phase 2 evaluation
USE-01	The normal authenticated entry requires one physical action from the student (a tap) and no action from the guard beyond a glance; time from tap to result ≤ 1.5 s (95th percentile) online, ≤ 2 s offline.	Herley [11]: the secure path must cost less than today's glance. H1, H7.	[S] 11, 17; [P] Q11a, observation [DATA REQUIRED]	M	Screens 1–5	Timing measurement at pilot gate
USE-02	A first-time guard, after ≤ 15 minutes of training, can correctly state the meaning and next step for every result screen without technical vocabulary.	Cranor [16]: comprehension stage. Ramesh persona.	[S] 12, 16; [P] B Q13 [DATA REQUIRED]	M	Screens 4–12 use plain bilingual text	Comprehension test with guards
USE-03	Authentication failure ("we don't recognise this credential") and authorization failure ("recognised, but not allowed here/now" — expired, revoked, wrong gate) are visually and verbally distinct on both guard and user displays, with distinct next steps.	Core project distinction; different responses required.	[S] 1, 14	M	Screens 6 vs 7, 8, 9	Guards sort screens into correct categories
USE-04	Every error/deny message states what happened (in role-appropriate detail) and exactly what to do next; no dead ends.	Nielsen #9; Whitten & Tygar [12].	[S] 12, 15	M	All DENY screens have "Next step" block	Heuristic + task test T2, T3, T6
USE-05	The guard interface never requires the guard to read more than the photo, one name, one status word and one line of instruction to make the routine decision.	Ramesh: one glance. SEC-08.	[S] 13, 16; [P] B Q11 [DATA REQUIRED]	M	Screen 5 layout	Eye-tracking optional; timed decision test
USE-06	System status is always visible on the guard screen: online/offline mode, revocation list age, reader health, pending alerts.	Nielsen #1; Yee visibility [13].	[S] 13, 15	M	Screen 16 status bar; screens 10, 11	Heuristic
USE-07	Learnability for students: no enrolment step is needed to use the card; phone enrolment takes ≤ 3 minutes and is optional.	Path of least resistance [13].	[S] 13	M	Enrolment described in spec	Timed enrolment
USE-08	Multimodal feedback for the result: colour (green/amber/red), icon ($\checkmark$ / ! / $\times$), distinct audio tone, and (on phone) haptic; never colour alone.	Accessibility (WCAG 1.4.1 [28]); outdoor glare; guard watches person not screen.	[S] 28	M	Screens 4–9	Accessibility audit
USE-09	Text contrast $\geq 4.5:1$, minimum 18 pt for status words on the guard display, readable in direct sunlight and at night; bilingual (Hindi/English) labels.	WCAG 1.4.3 [28]; observation of light conditions [DATA REQUIRED].	[S] 28; [P] D	M	All screens	Contrast tool; field test
USE-10	Error prevention: destructive admin actions (revoke, policy change) require confirmation showing the exact effect; guard "Mismatch" and "Call supervisor" are large, separated, and reversible until confirmed.	Nielsen #5; reversibility [13].	[S] 13, 15	M	Screens 16, 17, 18, 20	Heuristic; task T9
USE-11	Recognition over recall: guard next-step scripts are on screen, not memorised; admin forms show roster data rather than requiring typed IDs.	Nielsen #6.	[S] 15	S	Screens 6–12, 17	Heuristic
USE-12	Queue management: reader supports back-to-back taps with no reset step; result clears automatically after the person passes or after 5 s; a second reader lane can be added without software change.	H1, H7; peak load.	[P] observation [DATA REQUIRED]	S	Screen 5 auto-clear	Throughput test
USE-13	Trust and transparency: students can see why the system exists, what it records, and their own records (PRIV-07, PRIV-08); the user-facing display shows a short, respectful message on denial.	Q15c [DATA REQUIRED]; Meher dignity.	[P] Q15	S	Screens 4–9 user side; 20	Survey after pilot
USE-14	Accessibility of the physical interaction: reader mounted at a height reachable from a wheelchair (approx. 0.9–1.1 m), tap works through wallets/bags, phone path supports OS screen readers; a non-visual confirmation exists.	Q18 [DATA REQUIRED]; WCAG [28].	[S] 28; [P] Q18	M	Spec notes on screen 1, 2	Accessibility review

23. Non-Functional Requirements

ID	Category	Requirement	Measure / target	Evidence
NFR-01	Performance	End-to-end decision latency at gate	≤ 1.5 s p95 online; ≤ 2 s p95 offline (USE-01)	[S] 11
NFR-02	Performance	Throughput per reader lane	≥ 30 people/minute sustained with back-to-back taps	Observation [DATA REQUIRED]
NFR-03	Reliability	Reader operates correctly across expected outdoor conditions (temperature, humidity, dust, rain shelter) and after power interruption without manual reconfiguration	Vendor spec + field pilot	[A]
NFR-04	Availability	Gate authentication function available $\geq 99.5\%$ of operating hours, counting offline mode as available and Manual Verification Mode as degraded	Uptime log	[A]
NFR-05	Availability	Offline operation with cached verification material for $\leq N$ hours (N default 4) before degrading to manual	Fault injection (SEC-19)	[S] 2
NFR-06	Scalability	Supports the full campus population plus visitors and ≥ 10 gates/readers without architectural change; policy evaluation $O(1)$ per decision	Load test	[A]
NFR-07	Security	All SEC-xx requirements; standard primitives only; dependency vulnerability scan clean at release	OWASP ASVS L2 checklist [29]	[S] 29
NFR-08	Privacy	All PRIV-xx requirements; DPIA completed before any pilot with real student data	DPIA document	[S] 22, 26
NFR-09	Accessibility	Guard and student interfaces meet WCAG 2.2 AA where applicable; physical mounting per USE-14	Audit	[S] 28
NFR-10	Maintainability	Policy, thresholds, retention periods, and N are configuration, not code; components (reader firmware, auth service, policy engine, log service) are separately deployable; $\geq 50\%$ original code (course rule [43])	Code review	[S] 43
NFR-11	Auditability	100% of access decisions and admin actions logged with integrity protection; log verification tool provided	Verification run	[S] 29
NFR-12	Usability	All USE-xx; SUS score ≥ 70 from guards in Phase 2 pilot; task success $\geq 95\%$ for T1, T5, T6	Phase 2 study	[S] 15
NFR-13	Interoperability	Card credential based on ISO/IEC 14443 [23]; QR per ISO/IEC 18004 [25]; tokens per RFC 7519 [40] with Ed25519 [38]	Standards conformance	[S] 23, 25, 38, 40
NFR-14	Time synchronization	All readers and servers synchronised to ≤ 1 s (NTP); clock drift triggers a status warning; TOTP/token windows tolerate ± 1 step	Monitoring	[S] 37